Laboratorio SOC con Wazuh: guía paso a paso

Detección de ataques (Nmap, Hydra, RDP) con Wazuh, Suricata y mapeo a MITRE ATT&CK

1. Objetivo y alcance

Montar un laboratorio aislado de 4 máquinas virtuales para generar ataques controlados, detectarlos con **Wazuh** (SIEM/XDR), escribir **reglas personalizadas**, mapear cada alerta a **MITRE ATT&CK** y documentar el análisis como lo haría un analista SOC L1. El resultado es un repositorio de GitHub con reglas, configuraciones, evidencias y un README.

- **Defensivo:** todo el tráfico de ataque ocurre dentro de tu red virtual; nada sale a internet ni a tu red doméstica.
- **Versión:** esta guía usa la rama **4.14** de Wazuh, la estable al momento de escribirla. Wazuh 5.0 estaba en pre-lanzamiento y cambia detalles como la ubicación de las credenciales; si ya es estable cuando lo hagas, revisa su Quickstart.
- **Tiempo estimado:** 4 a 6 horas entre instalación y pruebas; otra hora para documentar.

2. Requisitos

2.1 Equipo anfitrión

- **RAM:** 16 GB como mínimo (32 GB ideal). Con 16 GB mantén apagada Kali mientras instalas y no abras otras aplicaciones pesadas.
- **CPU:** 4 núcleos o más, con virtualización (Intel VT-x / AMD-V) habilitada en la BIOS.
- **Disco:** 150 GB libres, de preferencia SSD.
- **Software:** VirtualBox 7.x (gratis) o VMware Workstation. La guía usa VirtualBox.

2.2 ISOs y descargas

- **Ubuntu Server 22.04 LTS** (ubuntu.com/download/server), para el servidor Wazuh y la víctima Linux.
- **Windows Server 2022 Evaluation** (Microsoft Evaluation Center, gratis por 180 días).
- **Kali Linux**, imagen de máquina virtual prearmada (kali.org/get-kali, sección Virtual Machines).

2.3 Máquinas virtuales

VM	Sistema	RAM	CPU	Disco	IP fija	Rol
wazuh-server	Ubuntu 22.04 Server	6 GB (8 ideal)	4	60 GB	10.10.10.10	Manager + Indexer + Dashboard
ubuntu-victim	Ubuntu 22.04 Server	2 GB	2	20 GB	10.10.10.20	Víctima: SSH, Apache, agente, Suricata
win-server	Windows Server 2022	3 GB	2	50 GB	10.10.10.30	Víctima: RDP y agente
kali-attacker	Kali Linux	2 GB	2	80 GB	10.10.10.40	Atacante

Conocimientos previos: comandos básicos de Linux (`cd`, `nano`, `systemctl`), nociones de redes (IP, puertos) y de logs. No se necesita ninguna cuenta de pago.

Aviso: ejecuta estos ataques solo contra tus propias VMs. Atacar sistemas ajenos es ilegal.

3. Fase 1: red virtual aislada

Usaremos una **NAT Network** de VirtualBox. Las VMs se ven entre sí, salen a internet para instalar paquetes y quedan aisladas de tu red doméstica.

1. En VirtualBox abre **Tools → Network → NAT Networks → Create** (la ruta varía un poco según la versión).

2. Nombre: `SOCLab`. IPv4 Prefix: `10.10.10.0/24`. **Desmarca "Enable DHCP"** (usaremos IP fijas).
3. Abre **Port Forwarding** de esa red y crea estas reglas (Host IP `127.0.0.1`): `8443 → 10.10.10.10:443` (dashboard), `2210 → 10.10.10.10:22` y `2220 → 10.10.10.20:22` (SSH para copiar y pegar comandos desde tu equipo).
4. En cada VM que crees: **Settings → Network → Adapter 1 → Attached to: NAT Network → SOCLab**.

Si una VM no tiene internet con IP fija, activa DHCP en la red, anota la IP con `ip a` y ajusta las IP de esta guía.

4. Fase 2: servidor Wazuh

1. Crea la VM `wazuh-server` (6 GB RAM, 4 CPU, 60 GB) e instala Ubuntu Server 22.04. Hostname `wazuh-server`, usuario `soc`, marca **Install OpenSSH server**.
2. En la pantalla de red del instalador elige IPv4 **Manual**: subred `10.10.10.0/24`, dirección `10.10.10.10`, gateway `10.10.10.1`, DNS `1.1.1.1,8.8.8.8`. Si la configuras después, edita el archivo de `/etc/netplan/` (ver abajo).
3. Actualiza el sistema e instala herramientas base.

```
sudo apt update && sudo apt -y upgrade
sudo apt -y install curl tar net-tools
```

Configuración de IP fija con netplan (solo si no la hiciste en el instalador). Confirma el nombre de la interfaz con `ip a` (suele ser `enp0s3`):

```
# sudo nano /etc/netplan/00-installer-config.yaml
network:
  version: 2
  ethernets:
    enp0s3:
      dhcp4: false
      addresses: [10.10.10.10/24]
      routes:
        - to: default
          via: 10.10.10.1
      nameservers:
        addresses: [1.1.1.1, 8.8.8.8]

sudo netplan apply
ping -c 2 8.8.8.8 && ping -c 2 google.com
```

4. Instala todos los componentes de Wazuh en el mismo equipo (tarda 10 a 20 minutos):

```
sudsud
sudo bash ./wazuh-install.sh -a
```

Al terminar muestra `INFO: Installation finished.` junto con el usuario `admin` y su contraseña. **Cópiala**: se muestra una sola vez. Si la pierdes, recupérala desde el directorio donde corriste el instalador:

```
sudo tar -O -xvf wazuh-install-files.tar wazuh-install-files/wazuh-passwords.txt
```

Desactiva el repositorio de Wazuh para evitar actualizaciones accidentales que rompan el laboratorio, y verifica los servicios:

```
sudo sed -i "s/^deb /#deb /" /etc/apt/sources.list.d/wazuh.list && sudo apt update
sudo systemctl is-active wazuh-manager wazuh-indexer wazuh-dashboard
```

Deben aparecer tres `active`. Desde el navegador de tu equipo abre `https://127.0.0.1:8443`, acepta el certificado autofirmado e ingresa con `admin`.

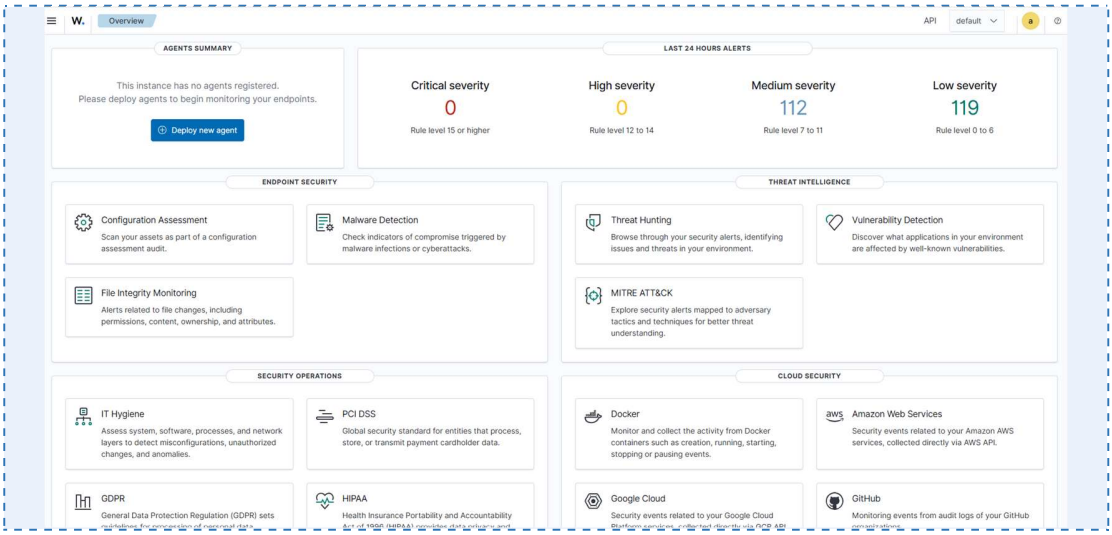


Fig 1. Dashboard activo de Wazuh.

5. Fase 3: víctima Linux (ubuntu-victim)

1. Crea la VM `ubuntu-victim`, instala Ubuntu Server 22.04 con IP `10.10.10.20` (gateway `10.10.10.1`) y OpenSSH.
2. Instala los servicios que serán objetivo y crea un usuario de laboratorio con contraseña débil a propósito (solo para esta demostración):

```
sudo apt update && sudo apt -y install openssh-server apache2 curl
sudo adduser labuser          # contraseña de laboratorio: sunshine
sudo sed -i 's/^#\?PasswordAuthentication.*/PasswordAuthentication yes/' /etc/ssh/sshd_config
sudo systemctl restart ssh
```

3. En el dashboard ve a **Agents → Deploy new agent**. Elige DEB amd64, dirección del servidor `10.10.10.10` y nombre `ubuntu-victim`. **Copia el comando que genera el dashboard**, porque trae la versión exacta (el agente nunca debe ser más nuevo que el manager). Tiene esta forma:

```
wget https://packages.wazuh.com/4.x/apt/pool/main/w/wazuh-agent/wazuh-agent_4.14.X-1_amd64.deb
sudo WAZUH_MANAGER='10.10.10.10' WAZUH_AGENT_NAME='ubuntu-victim' dpkg -i ./wazuh-agent_4.14.X-1_amd64.deb
sudo systemctl daemon-reload
sudo systemctl enable --now wazuh-agent
```

Verifica con `sudo systemctl status wazuh-agent` y confirma que el agente aparece como **Active** en el dashboard.

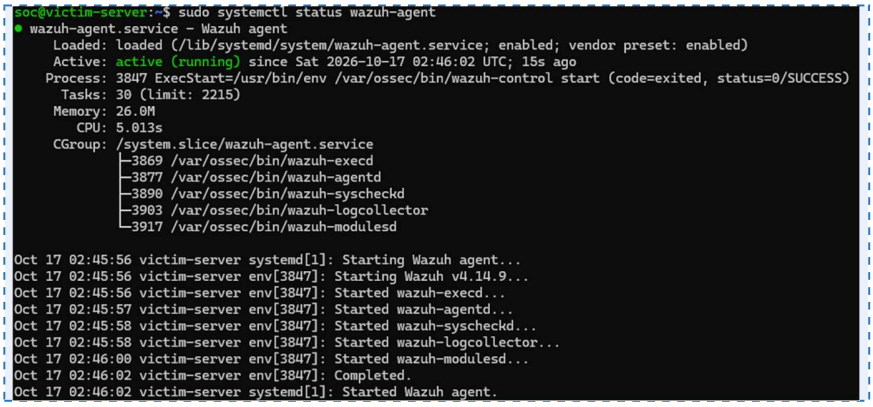


Fig 2. Verificación de la activación del agente Wazuh.

6. Fase 4: víctima Windows (win-server)

1. Crea la VM `win-server` con Windows Server 2022 Evaluation (Desktop Experience) y define una contraseña para `Administrator`.
2. Asigna IP fija: `ncpa.cpl` → Propiedades de IPv4 → `10.10.10.30`, máscara `255.255.255.0`, gateway `10.10.10.1`, DNS `1.1.1.1`.
3. Abre PowerShell como administrador y habilita RDP:

```
Set-ItemProperty -Path 'HKLM:\System\CurrentControlSet\Control\Terminal Server' -Name fDenyTSConnections -
Value 0
Enable-NetFirewallRule -DisplayGroup "Remote Desktop"
```

4. En el dashboard usa **Deploy new agent**, elige Windows, servidor `10.10.10.10` y nombre `win-server`. Copia el comando que genera; tiene esta forma:

```
Invoke-WebRequest -Uri https://packages.wazuh.com/4.x/windows/wazuh-agent-4.14.X-1.msi -OutFile
$env:tmp\wazuh-agent.msi
msiexec.exe /i $env:tmp\wazuh-agent.msi /q WAZUH_MANAGER='10.10.10.10' WAZUH_AGENT_NAME='win-server'
NET START WazuhSvc
```

Opcional (suma mucho al portafolio): Sysmon. Descarga Sysmon de Sysinternals y la configuración de SwiftOnSecurity (github.com/SwiftOnSecurity/sysmon-config), instala con `sysmon64.exe -accepteula -i sysmonconfig-export.xml` y agrega este bloque dentro de `<ossec_config>` en `C:\Program Files (x86)\ossec-agent\ossec.conf`. Luego reinicia con `Restart-Service WazuhSvc`.

```
<localfile>
  <location>Microsoft-Windows-Sysmon/Operational</location>
  <log_format>eventchannel</log_format>
</localfile>
```

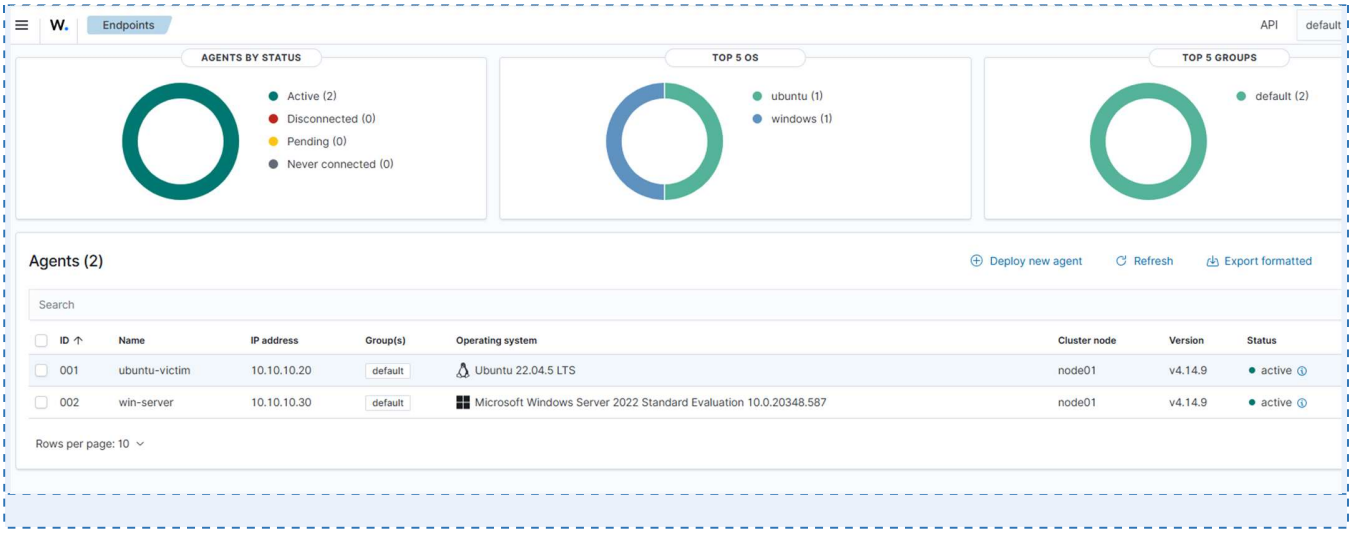


Fig 3. Panel general del Dashboard de Wazuh (*Endpoints*) donde se confirma la correcta comunicación y estado **Active** de los dos agentes objetivo: `ubuntu-victim` (`10.10.10.20`) y `win-server` (`10.10.10.30`).

7. Fase 5: Suricata en la víctima Linux

El agente de Wazuh lee logs, y un escaneo Nmap no deja líneas de log en el host. Para detectarlo instalamos **Suricata** (IDS de red) y hacemos que Wazuh lea su archivo `eve.json`.

```
sudo add-apt-repository -y ppa:oisf/suricata-stable
sudo apt update && sudo apt -y install suricata
sudo sed -i 's/interface: eth0/interface: enp0s3/' /etc/suricata/suricata.yaml
sudo suricata-update
```

El `HOME_NET` por defecto ya incluye `10.0.0.0/8`, así que cubre el laboratorio. Crea una regla propia de detección de escaneo SYN y regístrala:

```
echo 'alert tcp any any -> $HOME_NET any (msg:"LAB Possible port scan (SYN)"; flags:S; detection_filter:
track by_src, count 20, seconds 5; classtype:attempted-recon; sid:1000001; rev:1;)' | sudo tee
/var/lib/suricata/rules/local.rules
sudo nano /etc/suricata/suricata.yaml
```

En `rule-files:` deja `- suricata.rules` y agrega debajo `- local.rules`. Valida y arranca:

```
sudo suricata -T -c /etc/suricata/suricata.yaml -v
sudo systemctl enable suricata && sudo systemctl restart suricata
```

Haz que el agente envíe `eve.json` a Wazuh: edita `sudo nano /var/ossec/etc/ossec.conf` y agrega antes de `</ossec_config>`:

```
<localfile>
  <log_format>json</log_format>
  <location>/var/log/suricata/eve.json</location>
</localfile>

sudo systemctl restart wazuh-agent
```

8. Fase 6: Kali Linux (atacante)

1. Importa la VM de Kali, conéctala a la NAT Network `SOCLab`, inicia sesión (`kali` / `kali`) y cambia la contraseña con `passwd`.
2. Asigna IP fija (revisa el nombre de la conexión con `nmcli con show`):

```
sudo nmcli con mod "Wired connection 1" ipv4.method manual ipv4.addresses 10.10.10.40/24 ipv4.gateway
10.10.10.1 ipv4.dns 1.1.1.1
sudo nmcli con up "Wired connection 1"
ping -c 2 10.10.10.10 && ping -c 2 10.10.10.20 && ping -c 2 10.10.10.30
```

3. Prepara un diccionario corto (contiene `sunshine`, la contraseña de `labuser`) y uno aún más corto para RDP:

```
sudo gunzip -k /usr/share/wordlists/rockyou.txt.gz
head -n 300 /usr/share/wordlists/rockyou.txt > ~/pass.txt
head -n 30 ~/pass.txt > ~/pass30.txt
```

Apaga las cuatro VMs y toma un **snapshot** de cada una (`lab-base`). Así puedes repetir los ataques desde un estado limpio.

9. Fase 7: reglas personalizadas en Wazuh

En el servidor Wazuh agrega estas reglas al final de `/var/ossec/etc/rules/local_rules.xml` (los IDs 100100+ están reservados para reglas propias). Verifica los IDs padre (`86601`, `5760`, `60103`) en **Server management → Rules**, porque pueden variar entre versiones.

```
<group name="local,lab,">

  <!-- Escaneo de puertos detectado por la regla propia de Suricata -->
  <rule id="100100" level="10">
    <if_sid>86601</if_sid>
    <field name="alert.signature">LAB Possible port scan</field>
    <description>LAB: posible escaneo de puertos desde $(src_ip) (Suricata)</description>
    <mitre><id>T1046</id></mitre>
    <group>recon,</group>
  </rule>

  <!-- Fuerza bruta SSH: 8 fallos en 2 minutos desde la misma IP -->
  <rule id="100101" level="12" frequency="8" timeframe="120">
    <if_matched_sid>5760</if_matched_sid>
    <same_source_ip />
    <description>LAB: fuerza bruta SSH desde $(srcip) (8 fallos en 2 min)</description>
```

```
    <mitre><id>T1110.001</id></mitre>
    <group>authentication_failures,</group>
  </rule>

  <!-- Usuario agregado al grupo local de administradores en Windows (evento 4732) -->
  <rule id="100102" level="12">
    <if_sid>60103</if_sid>
    <field name="win.system.eventID">^4732$</field>
    <field name="win.eventdata.targetUserName">^Administrators$|^Administradores$</field>
    <description>LAB: usuario agregado al grupo Administrators en $(win.system.computer)</description>
    <mitre><id>T1098</id></mitre>
    <group>account_changed,</group>
  </rule>

</group>
```

Prueba una línea de log real antes de reiniciar. Ejecuta `sudo /var/ossec/bin/wazuh-logtest` y pega:

```
Oct 15 10:00:00 ubuntu-victim sshd[1234]: Failed password for labuser from 10.10.10.40 port 4444 ssh2
```

Debe decodificar como `sshd` y disparar la regla `5760`. Valida la sintaxis y reinicia:

```
sudo /var/ossec/bin/wazuh-analysisd -t
sudo systemctl restart wazuh-manager
```

Opcional: respuesta activa (mitigación automática)

Para que Wazuh bloquee la IP atacante 3 minutos cuando salte la regla `100101`, agrega esto en `/var/ossec/etc/ossec.conf` del servidor (antes de `</ossec_config>`) y reinicia el manager. Es un buen punto para tu README: detección y respuesta.

```
<active-response>
  <command>firewall-drop</command>
  <location>local</location>
  <rules_id>100101</rules_id>
  <timeout>180</timeout>
</active-response>
```

10. Fase 8: ejecutar los ataques y analizar las alertas

Enciende las cuatro VMs. Ejecuta cada escenario, espera 30 a 60 segundos y revisa el dashboard en **Threat Hunting → Events** (el nombre del menú varía por versión). Filtros útiles: `agent.name: ubuntu-victim`, `rule.id: 100101`, `rule.mitre.id: T1110.001`, `rule.level >= 10`.

#	Escenario	Comando (desde Kali salvo indicación)	Detección esperada	MITRE ATT&CK
A	Escaneo de puertos	`nmap -sS -sV -p- -T4 10.10.10.20`	Alertas de Suricata y regla propia `100100`	T1046 Network Service Discovery
B	Fuerza bruta SSH	`hydra -l labuser -P ~/pass.txt -t 4 ssh://10.10.10.20`	Reglas `5760`/`5763` y regla propia `100101`; al acertar la clave puede aparecer una alerta de fallos seguidos de éxito	T1110.001 Password Guessing
C	Fallos de inicio de sesión RDP	`hydra -t 1 -l Administrator -P ~/pass30.txt rdp://10.10.10.30`	Evento 4625: reglas como `60122` y `60204` (varios fallos)	T1110 Brute Force
D	Persistencia simulada (en win-server, PowerShell admin)	`net user labbackdoor "P@ssw0rd-Lab1" /add` y luego `net localgroup Administrators labbackdoor /add`	Eventos 4720 y 4732; regla propia `100102`	T1136.001 Create Account; T1098 Account Manipulation

Notas por escenario:

- **A:** si no ves alerta, verifica primero Suricata con `sudo tail -f /var/log/suricata/eve.json | grep '"event_type":"alert"'` en la víctima.
- **B:** si activaste la respuesta activa, verás que Kali pierde el acceso SSH durante 3 minutos; captura eso como evidencia de mitigación.
- **C:** Hydra con RDP puede ser inestable con NLA. Alternativa: `for p in 123456 admin password qwerty letmein; do xfreerdp /v:10.10.10.30 /u:Administrator /p:$p /cert:ignore +auth-only; done` (en versiones nuevas el binario se llama `xfreerdp3`).
- **D:** al terminar, limpia con `net user labbackdoor /delete`.

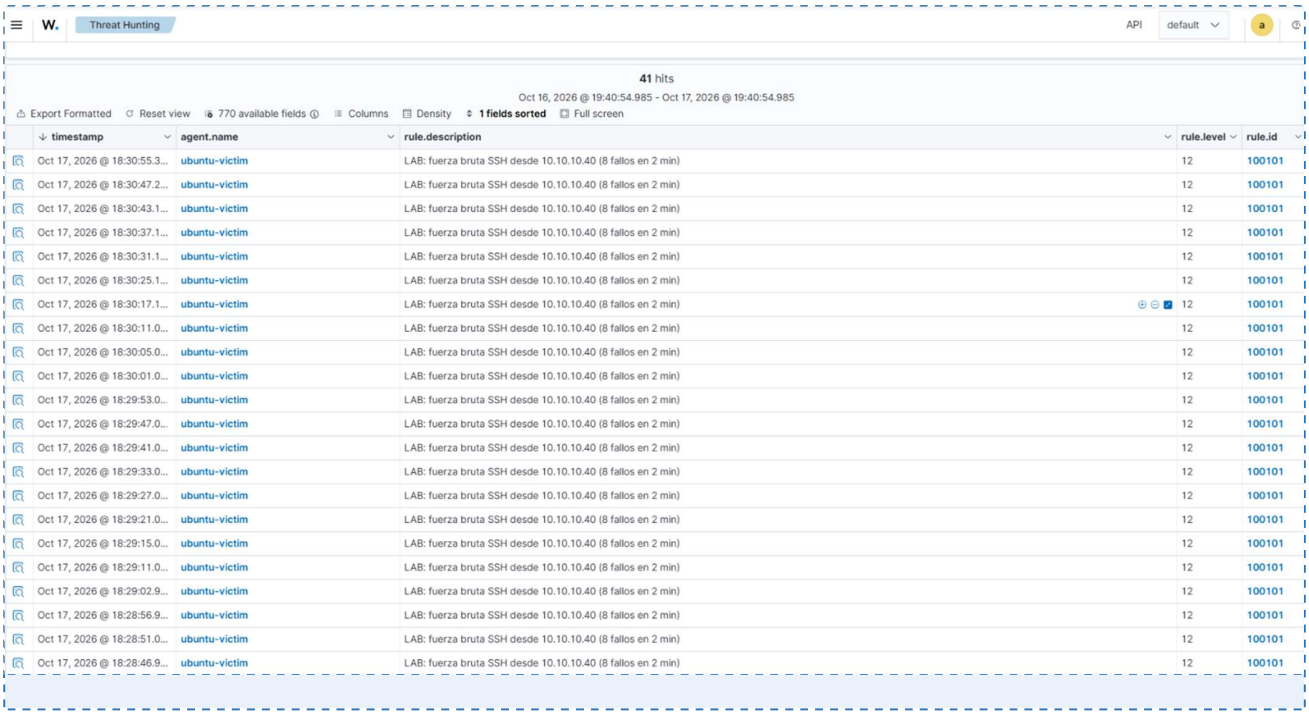


Fig 4. Panel de *Threat Hunting* mostrando la activación en ráfaga de la regla personalizada `100101` (Nivel 12). La regla correlaciona múltiples intentos fallidos de autenticación SSH provenientes de la IP atacante `10.10.10.40` dentro de un umbral de tiempo predefinido.

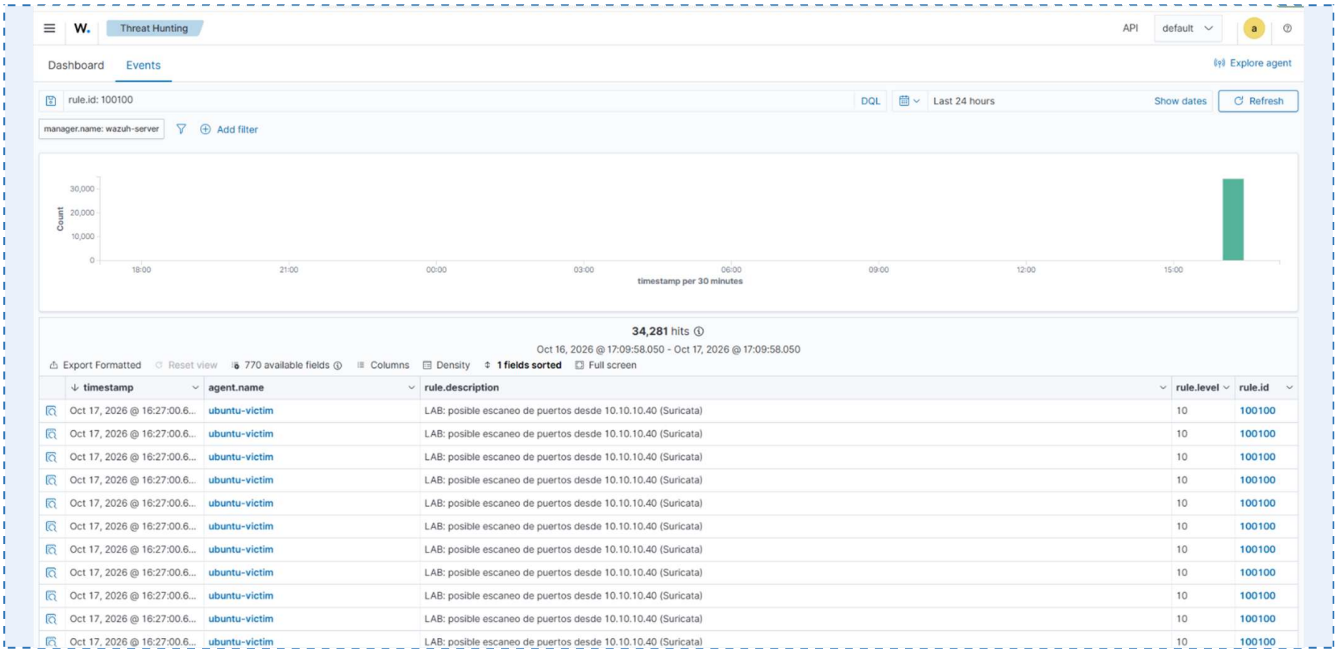


Fig 5. Ingesta y análisis del log `eve.json` generado por el IDS **Suricata**. Muestra la detección masiva de escaneo TCP SYN mediante la regla personalizada `100100` (Nivel 10) al ejecutar `Nmap` desde la máquina atacante.

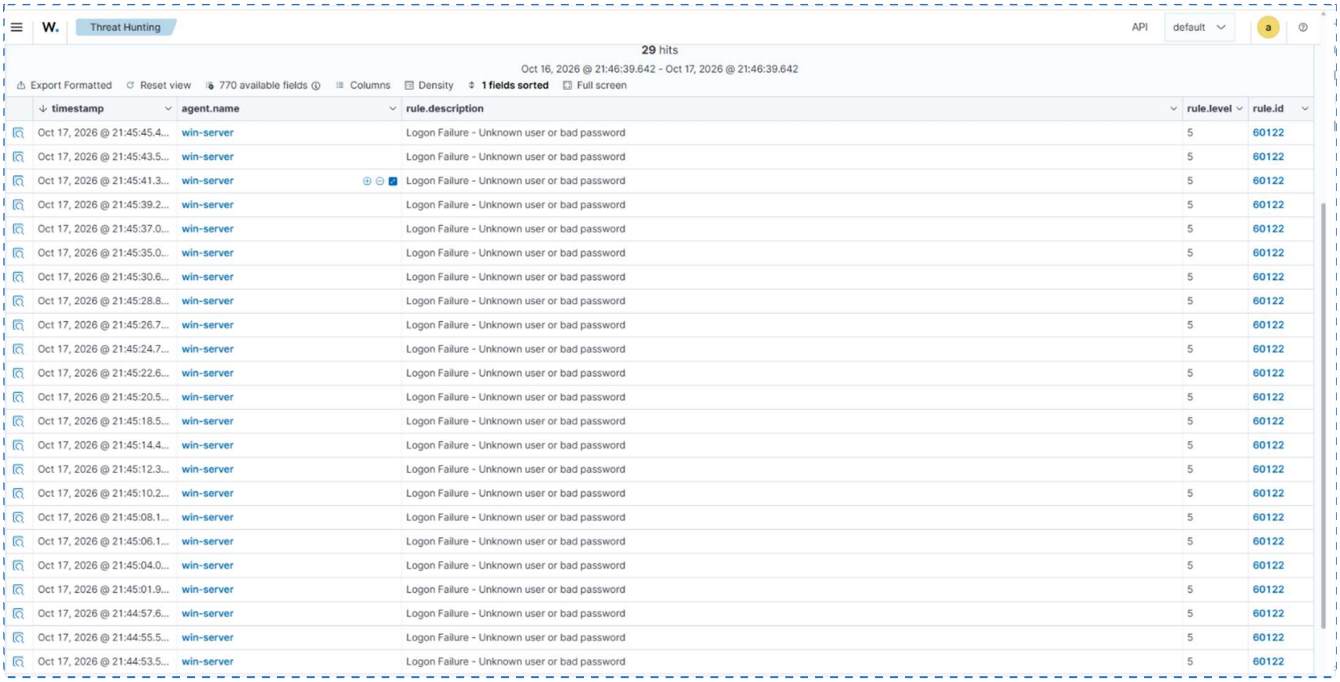


Fig 6. Secuencia de eventos registrando fallos de autenticación RDP (`Logon Failure`, Event ID `4625` / Regla `60122`) en el servidor Windows Server 2022 objetivo, generados durante la prueba de diccionario con Hydra.

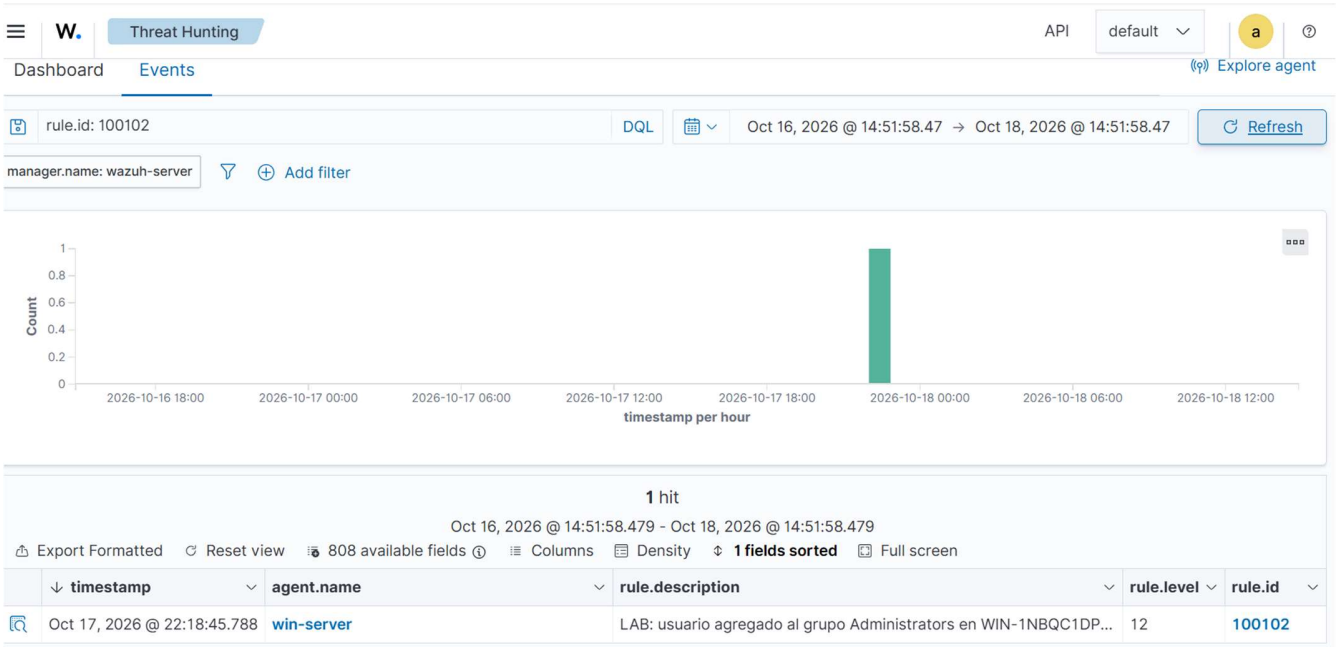


Fig 7. Alerta de severidad alta (Nivel 12, Regla `100102`) que detecta la adición de una cuenta no autorizada al grupo local `Administrators` de Windows (Event ID `4732`), identificando un intento de persistencia y elevación de privilegios.

Plantilla de análisis tipo L1

Documenta cada alerta relevante con esta tabla (es lo que más valoran en una entrevista, porque muestra criterio de triaje):

Campo	Contenido
Alerta / regla	ID de regla, descripción y nivel
Fecha y agente	Marca de tiempo y nombre del agente afectado
Origen y destino	IP atacante, IP víctima, puerto, usuario
Evidencia	Log o evento que la originó (fragmento y captura)
Técnica MITRE	ID y táctica
Evaluación	Verdadero positivo o falso positivo, con la razón
Severidad y decisión	Cerrar, monitorear o escalar a L2, con justificación
Acción recomendada	Bloqueo de IP, reinicio de credenciales, endurecimiento de SSH o RDP, etc.

11. Fase 9: documentar y subir a GitHub

Estructura sugerida del repositorio `wazuh-soc-lab`:

```
wazuh-soc-lab/
├── README.md
├── docs/
│   ├── guia-laboratorio-wazuh.pdf
│   └── analisis-alertas.md
├── rules/
│   ├── local_rules.xml          (reglas Wazuh 100100-100102)
│   └── local.rules              (regla Suricata sid 1000001)
├── configs/
│   ├── agent-ubuntu-eve-json.xml
│   └── active-response.xml
├── scripts/
```

```
│   └── escenarios-ataque.sh     (comandos de la sección 10)
└── evidence/
    ├── 01-agentes-activos.png
    ├── 02-ssh-bruteforce.png
    └── ...
```

- **Antes de subir, revisa que no haya secretos:** nada de `wazuh-passwords.txt`, contraseñas de las VMs ni capturas con la contraseña visible. Las IP `10.10.10.x` son privadas y no hay problema.
- **Capturas:** nómbralas con prefijo numérico (`01-`, `02-`…) y enlázalas desde el README.
- **README:** usa el archivo README.md que acompaña esta guía y completa los campos marcados con `[completar]` con tus resultados reales.

```
cd wazuh-soc-lab
git init
git add .
git commit -m "Laboratorio SOC con Wazuh: reglas, escenarios y evidencias"
git branch -M main
git remote add origin https://github.com/<tu-usuario>/wazuh-soc-lab.git
git push -u origin main
```

12. Solución de problemas

Síntoma	Diagnóstico probable	Comando para corregir o verificar
Agente en “Disconnected” o “Never connected”	El agente no llega a los puertos 1514/1515 del manager	En la víctima: `sudo tail -n 30 /var/ossec/logs/ossec.log`. En el servidor: `sudo ss -tlnp | grep -E '1514|1515'`. Prueba la conexión: `nc -zv 10.10.10.10 1514`
Dashboard no carga	Servicio caído o poca RAM	`free -h` y `sudo systemctl restart wazuh-indexer wazuh-manager wazuh-dashboard`. Si el indexer cae, sube la RAM a 8 GB
VM sin internet con IP fija	Gateway o DNS incorrectos	`ip route`, `ping 10.10.10.1`, `resolvectl status`. Si falla, activa DHCP en la NAT Network
Regla propia no dispara	XML inválido o ID padre incorrecto	`sudo /var/ossec/bin/wazuh-analysisd -t` y prueba la línea en `sudo /var/ossec/bin/wazuh-logtest`
Suricata no genera alertas	Interfaz equivocada o regla no cargada	`ip a`, `sudo suricata -T -c /etc/suricata/suricata.yaml -v`; prueba sin validar checksums: `sudo suricata -c /etc/suricata/suricata.yaml -i enp0s3 -k none`
No llegan eventos de Suricata a Wazuh	El agente no lee `eve.json`	`sudo grep -n eve.json /var/ossec/etc/ossec.conf` y `sudo systemctl restart wazuh-agent`
Agente Windows no inicia	Dirección del manager o servicio	`Get-Content "C:\Program Files (x86)\ossec-agent\ossec.log" -Tail 20` y `NET START WazuhSvc`
Hydra RDP falla o se cuelga	NLA o demasiados hilos	Usa `-t 1` o el bucle con `xfreerdp` de la sección 10